Website Vulnerability Assessment & Penetration Test Report

Target: https://www.hackthissite.org/

www.hackthissite.org_VAPT_Report
Generated 2026-11-09 06:28:11Z

Generated by Automated Website VAPT Framework v1.0.0 by Shrayan Biswas · LinkedIn

1. Executive summary

8 findings recorded for https://www.hackthissite.org/: 0 Critical, 0 High, 1 Medium, 3 Low, 4 Informational. Automated checks are indicators and must be validated; items marked CANDIDATE need manual confirmation.

2. Scope

Scope: https://www.hackthissite.org/. Testing consisted of non-destructive automated checks plus any manual findings recorded in this register.

3. Methodology

OWASP WSTG-aligned phases: reconnaissance, attack-surface mapping, configuration, authentication, authorization, input validation, session, API, client-side, validation, CVSS 3.1 scoring.

4. Environment and tools

Python 3 (urllib, ssl, socket), Flask; optional: Nmap, WhatWeb, Nikto, SSLScan; manual: Burp Suite, OWASP ZAP, SQLmap

5. Scans performed

Scan	Started (UTC)	Status	Requests	Modules
No scans recorded.				

6. Vulnerability summary

ID	Title	Severity	CVSS	Status
e5d48fa2	Missing clickjacking protection	**Medium**	4.2	Open
aa6bf44e	Missing X-Content-Type-Options header	Low	3.1	Open
823c5dd5	Wildcard CORS policy on landing page	Low	3.1	Open
2f7119fd	Cookie 'HackThisSite' missing Secure, HttpOnly, SameSite	Low	3.1	Open
7d530ce5	robots.txt reveals paths	*Informational*	0.0	Open
419b614c	Missing Permissions-Policy header	*Informational*	0.0	Open
6e23f786	API documentation exposed: /api-docs	*Informational*	0.0	Open
395d2879	No rate limiting seen on burst of 15 requests	*Informational*	0.0	Open

7. Detailed findings

---

e5d48fa2 - Missing clickjacking protection

Severity: Medium (CVSS 4.2, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N`)
Affected component: / **Phase:** Phase 9 **Status:** Open

Description: Neither X-Frame-Options nor CSP frame-ancestors is present.

Impact / business impact: Page may be framed by a malicious site (clickjacking).

Proof of concept / evidence:

```
See evidence/ folder
```

Recommendation: Add X-Frame-Options: DENY (or SAMEORIGIN) or CSP frame-ancestors.

Retest notes: Not yet retested

aa6bf44e - Missing X-Content-Type-Options header

Severity: Low (CVSS 3.1, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Browsers may MIME-sniff responses.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'x-content-type-options' absent from response.
```

Recommendation: Add: X-Content-Type-Options: nosniff

Retest notes: Not yet retested

823c5dd5 - Wildcard CORS policy on landing page

Severity: Low (CVSS 3.1, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Access-Control-Allow-Origin: * is returned.

Impact / business impact: Any website can read non-credentialed responses.

Proof of concept / evidence:

```
Access-Control-Allow-Origin: *
```

Recommendation: Restrict CORS to trusted origins.

Retest notes: Not yet retested

2f7119fd - Cookie 'HackThisSite' missing Secure, HttpOnly, SameSite

Severity: Low (CVSS 3.1, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N`)
Affected component: `Set-Cookie` **Phase:** Phase 7 **Status:** Open

Description: Cookie lacks recommended security attributes.

Impact / business impact: Increased exposure to theft or CSRF.

Proof of concept / evidence:

```
HackThisSite=<redacted>; expires=tue, 10-nov-2026 05:47:30 gmt; path=/
```

Recommendation: Set Secure, HttpOnly and SameSite=Lax/Strict on session cookies.

Retest notes: Not yet retested

7d530ce5 - robots.txt reveals paths

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/robots.txt` **Phase:** Phase 1 **Status:** Open

Description: robots.txt lists paths that may hint at sensitive areas.

Impact / business impact: Information disclosure that helps attackers focus.

Proof of concept / evidence:

```
Disallow: /missions/
Disallow: /killing/all/humans/
```

Recommendation: Do not rely on robots.txt for secrecy; protect sensitive paths with access control.

Retest notes: Not yet retested

419b614c - Missing Permissions-Policy header

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Browser features are not explicitly restricted.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'permissions-policy' absent from response.
```

Recommendation: Add: Permissions-Policy: geolocation=(), camera=(), microphone=()

Retest notes: Not yet retested

6e23f786 - API documentation exposed: /api-docs

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/api-docs` **Phase:** Phase 8 **Status:** Open

Description: API schema is publicly reachable.

Impact / business impact: Gives attackers a map of every endpoint.

Proof of concept / evidence:

```
GET /api-docs -> 200
```

Recommendation: Restrict docs to authenticated/internal users.

Retest notes: Not yet retested

395d2879 - No rate limiting seen on burst of 15 requests

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/api` **Phase:** Phase 4/8 **Status:** Open

Description: A short burst was not throttled. This is only a hint.

Impact / business impact: Brute-force and scraping may be possible - test login/reset endpoints manually.

Proof of concept / evidence:

```
See evidence/ folder
```

Recommendation: Add per-IP/per-account rate limits, especially on authentication.

Retest notes: Not yet retested

8. Retesting results

- No retests recorded yet.

9. Conclusion

Prioritise Critical/High items, then re-run the scan and update statuses to Retest Passed.

Automated Website VAPT Framework v1.0.0 © 2026 Shrayan Biswas · MIT License · https://www.linkedin.com/in/shrayan-biswas-a1259225a/